KINU

Security Report
v1.1 · October 2026

SECURITY & TRANSPARENCY

KINU Security Report

Internal review of the KINU web app, its transaction guard and server functions, including an internal penetration test — with the protections in place, official accounts and the incident response plan.

4	15	14	1
Reviews	**Findings**	**Fixed**	**Accepted**
12 – 19 Oct 2026	across 4 reviews	in production	low severity

High 2 · Medium 7 · Low–medium 1 · Low 5 — No critical findings

PROJECT
KINU · kinudefi.com
Non-custodial DeFi hub on NEAR

PREPARED BY
KINU team
Internal review, not a third-party audit

SCOPE
App, transaction guard, server functions
Swaps · Liquidity · Bridge · Earn · Treasury

REPORT DATE
19 October 2026
Code: KINUtheDog · kinu-platform

KINU holds no keys and no funds. Every transaction is signed in the user's own wallet.

1. Summary

KINU is a non-custodial web app. It has **no smart contracts of its own**: it builds transactions for contracts run by Rhea Finance, Intear and NEAR Intents, and the user signs every one of them in their own wallet. KINU never holds keys or funds.

The security surface is therefore the app (what it asks the wallet to sign), its server functions (quote and intent proxies that keep KINU's NEAR Intents partner key off the browser), and the website itself. Four internal reviews between 12 and 19 October 2026 found fifteen issues; fourteen are fixed and one low-severity item is accepted. The reviews read the code, tried attack scenarios and checked real transactions; every fix was reviewed and approved by the team.

> This is an internal review by the KINU team, not an independent audit. Rhea Finance's contracts are audited by Trail of Bits, BlockSec and Resonance (guide.rhea.finance/developers/audits). A third-party review of KINU will be published when completed, and any future KINU contract will be audited before launch.

2. Scope and method

AREA	IN SCOPE
Transaction guard	`src/lib/txGuard.js` : every request is checked before the wallet opens (contracts, methods, receivers, deposits, fee caps).
Swaps and liquidity	Rhea SmartRouter and CLMM quotes, Intear aggregator route checks (`src/lib/intearRouter.js`), platform fee.
Bridge, Earn, Treasury	NEAR Intents 1Click quotes, signature checks and request binding (`src/lib/intents.js` , `src/lib/earn.js`), signed intents, intents.near calls.
Server functions	`api/intents-quote.js` , `api/intents-intent.js` , `api/_origin.js` : origin checks, field allow-lists, rate limits, secret handling.
Website	Content-Security-Policy and headers (`vercel.json`), wallet redirects, dependencies (npm audit).

Method: code review of each flow, hostile-input cases (forged quotes, crafted links, hostile tokens), on-chain checks of real transactions, and a run of every page for runtime errors. The 19 October internal penetration test follows the blockchain penetration-testing method published by BlockSec (it was not performed or reviewed by BlockSec): (1) frontend and signing intent — what the user sees, signs and executes stays the same; (2) approval and withdrawal controls, including the server functions; (3) fund logic — amounts, precision, rounding, fees; (4) on-chain outcomes. Attacks were tried on a local copy and with read-only requests; no funds were moved and no third-party contract was attacked.

3. Findings

19 Oct 2026 · Internal penetration test (BlockSec's published method)

SEVERITY	FINDING	STATUS
High	Rhea SmartRouter routes were signed without reading who receives the output. The route message is only obfuscated, and it names the receiver (`receive_user`); a tampered or compromised quote API could have paid a swap's output to another account.	**Fixed.** The route is decoded and must belong to and pay the user, when quoted and again before the wallet opens. Tested with forged routes: refused.
Medium	The final check before signing (transaction guard) did not read the messages of DEX transfers (CLMM and exchange swaps, Intear DEX operations); it relied on earlier checks.	**Fixed.** Any message paying the output to another account is refused at signing time. All real routes still pass.
Medium	Earn and Treasury withdrawals accepted a `token_diff` intent that only gives tokens away, which any solver could fill for nothing.	**Fixed.** Only a transfer of the quoted amount to the quote's deposit address is ever signed.
Low	Pay from wallet (EVM) did not name the chain in the transaction.	**Fixed.** The transaction carries its chain id; a wallet on another network refuses it.
Low	NEAR Intents quotes did not bind the slippage that was asked for.	**Fixed.** The echoed slippage must match.
Low	Advisories in the HERE and Meteor wallet libraries (npm audit, 7 rated high upstream).	**Fixed.** The affected dependencies (bs58, bn.js, nanoid) are pinned to patched versions: 7 high advisories down to 0.

Checked and found sound: the Telegram bot webhook (secret required, external names escaped), security headers (strict CSP, no framing, HSTS), the quote and intent functions (origin checks, field allow-lists, server-side fee, rate limits) and the Bridge withdrawal binding.

18 Oct 2026 · Earn and Treasury withdrawals, server functions

SEVERITY	FINDING	STATUS
Medium	A key could be registered on intents.near without proof that it belongs to the account.	**Fixed.** The wallet's NEP-413 signature is verified for the exact message, and the key must be a full-access key of the account.
Medium	Scripts could fake the Origin header and use KINU's NEAR Intents partner quota.	**Fixed.** Per-IP rate limits: 60/min on quotes, 20/min on intents.
Low	Transitive advisories in wallet libraries (npm audit).	**Accepted.** No path to user funds; updated with wallet library releases.

17 Oct 2026 · Bridge (NEAR Intents 1Click)

SEVERITY	FINDING	STATUS

High	A genuine signed quote made for another recipient, refund address or amount would still verify.	**Fixed.** The quoted request must match what KINU sent, field by field.
Medium	A withdrawal transfer was not bound to its quote.	**Fixed.** A verified deposit address can only receive that quote's token and exact amount.
Low	A typed NEAR account was not checked to exist.	**Fixed.** A missing account blocks the deposit.

12 Oct 2026 · Platform: swaps, liquidity, wallet redirects

SEVERITY	FINDING	STATUS
Medium	Router quotes were used as returned.	**Fixed.** Amount and token path must match what the user typed.
Medium	A hostile token could ask for a large registration fee.	**Fixed.** 0.05 NEAR per token, 2 NEAR per signing request.
Low–medium	Crafted links could show fake wallet messages.	**Fixed.** Only redirects KINU started are shown.

4. Protections in place

Every transaction

- Allow-list of contracts and methods; plain transfers, key changes and deploys always refused.
- Tokens only go into the DEX contracts; every route message is read, and the swap output must come back to the user.
- Fees capped and checked against the published rate.
- Router quotes must match the typed amount and pair.
- NEAR Intents quotes need a valid 1Click signature and must match the request; tokens only go to that quote's deposit address, for its exact amount.
- On intents.near: keys registered only after signature and full-access checks; withdrawals only to the user's own account.

The website and servers

- Strict Content-Security-Policy, HSTS, no framing, no MIME sniffing.
- No secrets in the app; the NEAR Intents partner key lives only on the server.
- Server functions answer only KINU's pages, accept only known fields and are rate-limited.
- Wallet redirect messages shown only for redirects KINU started.
- Open source; no source maps published.

5. Official accounts and contracts

KINU	USED BY KINU (THIRD-PARTY)

Treasury	`kinu-treasury.near`
$KINU token	`kinu-3.nearlytrade.near`
Website	`kinudefi.com`
X	`@KINUonNEAR`
Telegram bot	`@Kinu_LPbot`

`v2.ref-finance.near`	Rhea pools
`dclv2.ref-labs.near`	Rhea CLMM
`boostfarm.ref-labs.near`	Rhea farms
`aggregatedex.near`	Rhea router
`dex.intear.near`	Intear DEX
`intents.near`	NEAR Intents
`wrap.near`	Wrapped NEAR

Not official: `kinu.nearlytrade.near`, `kinu-2.nearlytrade.near` (earlier launches). Any other site, token, bot or "support" account using the KINU name is not KINU.

6. Incident response plan

KINU never holds user funds, so it cannot freeze or move them. Its commitments and the levers it has:

SEVERITY	EXAMPLE	FIRST RESPONSE
Critical	User funds at risk through KINU	Within 1 hour
High	A feature behaves unsafely, or a partner is under incident	Within 4 hours
Medium	Wrong data shown, degraded service	Within 24 hours
Low	Cosmetic or minor bugs	Within 3 days

1. **Stop.** Turn the affected feature off and redeploy, or roll the site back to the last safe version. Bridge and Earn stop at once when KINU's NEAR Intents key is withdrawn from the server.
2. **Warn.** Announce on X and Telegram what is affected and what to avoid. KINU never asks anyone to "validate" or "migrate" a wallet.
3. **Escalate.** Contract-level issues go to the owning team: Rhea (whose Guardians can pause its exchange), Intear, or NEAR Intents (whose Shield pauses chains).
4. **Report.** A post-incident report within 7 days: timeline, impact, fix, and what changes.

7. Reporting a vulnerability

Send it privately to **@KINUonNEAR** on X: what you found, steps to reproduce, and the page or transaction. You get a reply within 48 hours. Please don't publish a working exploit or use it beyond what proves the issue. With your permission you are credited in the fix. There is no paid bug bounty yet.

8. Risks that remain

- **Market risk.** Prices move; $KINU is a young token with thin liquidity.
- **Liquidity risk.** Impermanent loss; CLMM ranges stop earning out of range.
- **Protocol risk.** Swaps and pools run on Rhea and Intear contracts; Bridge, cross-chain swaps and Earn run on NEAR Intents, which had an incident on 30 September 2026 (refund validation, about $3.9M, per

BlockSec). KINU checks every transaction and stops transfers on chains NEAR Intents pauses, but cannot change how those contracts behave.

- **Data providers.** Prices, charts and history come from third parties; the wallet shows what is actually signed.

KINU is non-custodial software, not financial advice. This report describes the state of the code on 19 October 2026.